TRƯỜNG ĐẠI HỌC BÁCH KHOA – ĐẠI HỌC ĐÀ NẴNG
KHOA ĐIỆN TỬ VÀ TRÍ TUỆ NHÂN TẠO

BÁO CÁO TIẾN ĐỘ – NHÓM 7

PGP

Nguyên lý RSA và mô hình mã hóa lai RSA – AES

Học phần: PBL3: Mạng máy tính
GVHD: TS. Trần Thị Minh Hạnh

Sinh viên thực hiện:

- Vũ Duy Dương (106230007)
- Huỳnh Thiện Lộc (106230052)
- Phan Vinh Sơn (106230059)

Đà Nẵng, 2026

MỤC LỤC

1. Danh mục thuật ngữ và viết tắt **2**

2. Giới thiệu đề tài **3**
2.1. Bối cảnh kỹ thuật . . . 3
2.2. Mục tiêu . . . 3
2.3. Phạm vi . . . 3

3. Vì sao PGP sử dụng mã hóa lai? **4**
3.1. Nguyên lý kết hợp . . . 4

4. Quy trình Hybrid Encryption **4**
4.1. Sơ đồ tuần tự tương tác (Sequence Diagram) . . . 5

5. Thuật toán RSA – Quá trình tạo khóa **5**
5.1. Cơ chế giải thuật Euclid mở rộng tìm d . . . 6

6. Cài đặt RSA bằng Python **6**
6.1. Bảng đặc tả các hàm chính . . . 6
6.2. Mã nguồn cài đặt giải thuật Euclid mở rộng và RSA . . . 7

7. Ví dụ RSA – Mã hóa và giải mã **7**
7.1. Chuỗi chuyển đổi dữ liệu . . . 8

8. Tích hợp RSA và AES trong Hybrid Encryption **8**
8.1. Cấu trúc gói tin dữ liệu đóng gói (Packet Payload) . . . 8
8.2. Phân công nhiệm vụ hai phía . . . 8
8.3. Mã nguồn tích hợp then chốt (`src/hybrid_demo.py`) . . . 9

9. Demo chương trình và kết quả kiểm thử **9**
9.1. Minh chứng thực nghiệm (Terminal Execution Log) . . . 10

10. Kết quả đạt được và hướng phát triển **11**
10.1. Tổng kết khối lượng công việc . . . 11
10.2. Lộ trình kế hoạch triển khai giai đoạn tới (Roadmap) . . . 11

11. Câu hỏi thảo luận và phản biện (Q&A) **12**

TÀI LIỆU THAM KHẢO **14**

1. Danh mục thuật ngữ và viết tắt

Để văn phong báo cáo cô đọng, trong toàn bộ tài liệu các thuật ngữ mật mã học và mạng máy tính được phân loại và chuẩn hóa theo danh mục dưới đây:

Ký hiệu / Thuật ngữ	Phân loại	Tên tiếng Anh	Ý nghĩa chuyên môn
PGP	Tiêu chuẩn	Pretty Good Privacy	Giao thức mã hóa bảo vệ quyền riêng tư qua kênh mạng mở.
RSA	Bất đối xứng	Rivest – Shamir – Adleman	Hệ mật mã khóa công khai dựa trên độ khó bài toán phân tích số nguyên lớn.
AES	Đối xứng	Advanced Encryption Standard	Chuẩn mã hóa đối xứng khối tốc độ cao, dùng ma trận thay thế hoán vị SPN.
Hybrid Encryption	Kiến trúc	Mã hóa lai	Mô hình kết hợp AES (mã hóa dữ liệu) và RSA (bảo vệ khóa phiên).
Session Key	Khóa	Khóa phiên	Khóa đối xứng ngẫu nhiên chỉ có giá trị cho một phiên truyền thông duy nhất.
Public / Private Key	Khóa	Khóa công khai / Bí mật	Cặp khóa bất đối xứng: chia sẻ công khai để mã hóa / giữ bí mật để giải mã.
PKESK	Gói tin PGP	Public-Key Encrypted Session Key	Gói tin chứa Session Key đã được mã hóa bằng khóa công khai người nhận.
SEIPD	Gói tin PGP	Symmetrically Encrypted Integrity Protected Data	Gói tin chứa dữ liệu đã được mã hóa đối xứng kèm cơ chế kiểm tra toàn vẹn.
AES-GCM	Chế độ AES	Galois/Counter Mode	Chế độ mã hóa xác thực (AEAD) cung cấp đồng thời tính bí mật và toàn vẹn.
Authentication Tag	Toàn vẹn	Mã kiểm thực MAC	Giá trị kiểm tra giúp phía nhận phát hiện mọi hành vi can thiệp hay sửa đổi bản mã.
OAEP	Cơ chế đệm	Optimal Asymmetric Encryption Padding	Cơ chế đệm ngẫu nhiên an toàn chống tấn công chọn bản mã cho RSA.

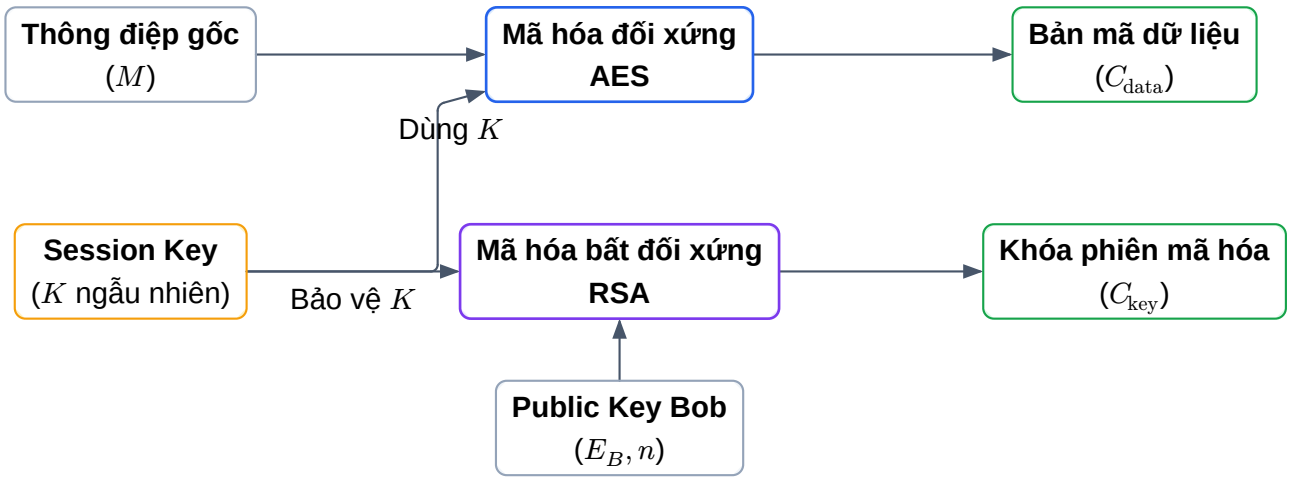
2. Giới thiệu đề tài

2.1. Bối cảnh kỹ thuật

Truyền thông an toàn trên mạng đòi hỏi đảm bảo đồng thời ba thuộc tính: tính bí mật, toàn vẹn và xác thực [1]:

- **Mã hóa đối xứng (AES):** Xử lý nhanh, hiệu quả với dữ liệu lớn nhưng phụ thuộc vào bài toán thỏa thuận khóa bí mật qua kênh truyền [2].
- **Mã hóa bất đối xứng (RSA):** Giải quyết việc trao đổi khóa bằng cặp Public/Private Key, nhưng tốc độ xử lý chậm do chi phí tính lũy thừa mô-đun lớn [3].

Chuẩn OpenPGP ([4], [5]) giải quyết sự đánh đổi này bằng kiến trúc **Hybrid Encryption**: dùng AES mã hóa dữ liệu và dùng RSA bảo vệ khóa phiên.



Hình 1: Sơ đồ nguyên lý mã hóa lai RSA – AES trong mô hình PGP

2.2. Mục tiêu

Chuẩn OpenPGP hoàn chỉnh chứa nhiều cơ chế phức hợp (hệ thống gói tin đa tầng, chứng thực Web of Trust, nén dữ liệu). Trong phạm vi đề tài môn học, nhóm tập trung thực nghiệm mô hình cốt lõi:

1. Nắm vững cơ sở số học của RSA (thuật toán Euclid mở rộng, định lý Euler).
2. Tự cài đặt thuật toán RSA bằng Python thuần để hiểu rõ bản chất tính toán.
3. Tích hợp RSA tự viết với AES-GCM thành luồng mã hóa lai hoàn chỉnh.
4. Thiết kế các kịch bản kiểm thử nhằm đánh giá tính đúng đắn và khả năng bắt lỗi toàn vẹn.

2.3. Phạm vi

- **Thực hiện:** Cài đặt Textbook RSA dạng số học, kết hợp thư viện chuẩn AES-GCM để gửi và nhận thông điệp có kiểm thực tag.

- **Chưa thực hiện:** Chưa áp dụng cơ chế đệm an toàn RSA-OAEP [3], chưa xây dựng mạng lưới tín nhiệm Web of Trust và cấu trúc nhị phân RFC 4880.

3. Vì sao PGP sử dụng mã hóa lai?

Mã hóa lai giải quyết bài toán dung hòa giữa tốc độ xử lý và khả năng phân phối khóa an toàn:

AES – Mã hóa đối xứng [6]	RSA – Mã hóa bất đối xứng [7]
Dùng chung một Session Key bí mật.	Dùng cặp Public Key và Private Key.
Tốc độ phần cứng cực nhanh, tối ưu cho dữ liệu lớn.	Tốc độ chậm do tính lũy thừa mô-đun trên số nguyên lớn.
Cần kênh an toàn để trao đổi khóa phiên.	Cho phép gửi khóa an toàn qua kênh công khai.
Không mã hóa được nếu chưa có khóa chung.	Không tối ưu để mã hóa trực tiếp khối dữ liệu dài.

3.1. Nguyên lý kết hợp

- AES chịu trách nhiệm mã hóa toàn bộ dữ liệu người dùng bằng khóa ngẫu nhiên K.
- RSA chịu trách nhiệm mã hóa duy nhất khóa K bằng Public Key của Bob (E_B).

Công thức đóng gói dữ liệu của PGP:

$$\text{Gói tin PGP} = \left\{ \text{RSA}_{E_B}(K), \quad \text{AES}_K(\text{Plaintext}) \right\}$$

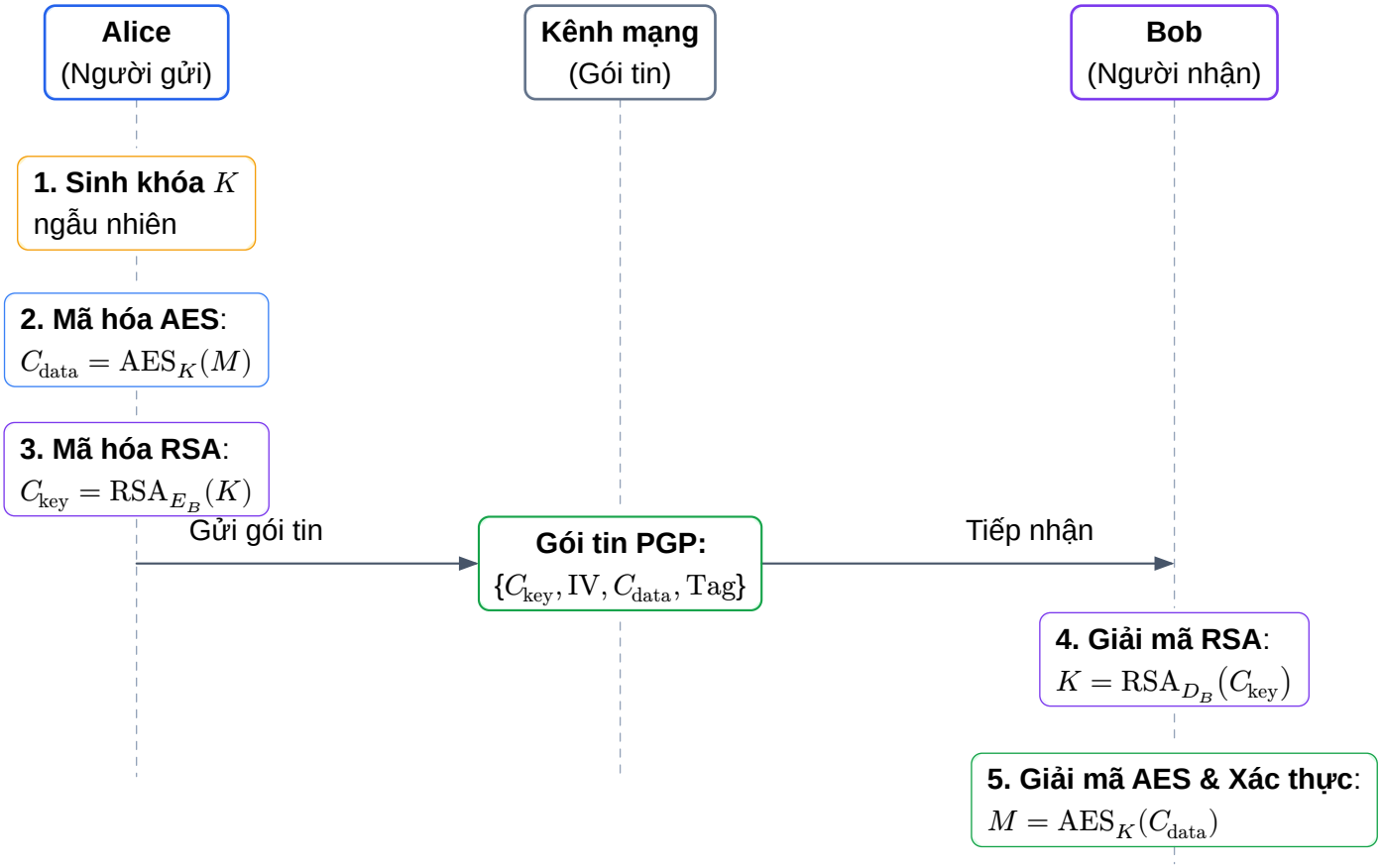
Kết luận: AES bảo vệ dữ liệu, RSA bảo vệ khóa phiên.

4. Quy trình Hybrid Encryption

Quy trình truyền tin an toàn giữa Alice (gửi) và Bob (nhận) gồm các bước sau:

Phía Alice (Mã hóa)	Phía Bob (Giải mã)
1. Sinh Session Key ngẫu nhiên (K). 2. Dùng AES mã hóa dữ liệu: $C_{\text{data}} = \text{AES}_K(M)$. 3. Dùng Public Key Bob mã hóa K: $C_{\text{key}} = \text{RSA}_{E_B}(K)$. 4. Ghép gói tin và gửi cho Bob.	1. Nhận gói tin từ Alice qua mạng. 2. Dùng Private Key Bob giải mã lấy lại: $K = \text{RSA}_{D_B}(C_{\text{key}})$. 3. Dùng K giải mã dữ liệu: $M = \text{AES}_K(C_{\text{data}})$. 4. Kiểm tra tính toàn vẹn qua Authentication Tag.

4.1. Sơ đồ tuần tự tương tác (Sequence Diagram)



Hình 2: Sơ đồ tuần tự quy trình truyền thông mã hóa lai PGP giữa Alice và Bob

5. Thuật toán RSA – Quá trình tạo khóa

Thuật toán RSA ([7]) dựa trên tính bất đối xứng tính toán của bài toán phân tích thừa số nguyên tố. Dưới đây là các bước sinh khóa với hai số nguyên tố nhỏ $p = 61, q = 53$:

Bước	Phép tính toán học	Kết quả minh họa
1. Số nguyên tố	Chọn ngẫu nhiên p, q ($p \neq q$)	$p = 61, q = 53$
2. Modulus	$n = p \times q = 61 \times 53$	$n = 3233$
3. Hàm Euler Phi	$\varphi(n) = (p-1)(q-1) = 60 \times 52$	$\varphi(n) = 3120$
4. Khóa công khai e	Chọn $1 < e < \varphi(n)$ sao cho $\gcd(e, \varphi(n)) = 1$	$e = 17$
5. Khóa bí mật d	$e \times d \equiv 1 \bmod \varphi(n)$ (Nghịch đảo modulo)	$d = 2753$

5.1. Cơ chế giải thuật Euclid mở rộng tìm d

Phương trình đồng dư $17d \equiv 1 \bmod 3120$ tương đương phương trình Bézout:

$$17d + 3120y = 1$$

Thực hiện chia Euclid:
1. $3120 = 183 \times 17 + 9$
2. $17 = 1 \times 9 + 8$
3. $9 = 1 \times 8 + 1$

Biểu diễn ngược số dư 1:

$$1 = 9 - (17 - 9) = 2 \times (3120 - 183 \times 17) - 17 = 2 \times 3120 - 367 \times 17$$

Hệ số của 17 là $x = -367$. Lấy modulo theo $\varphi(n) = 3120$:

$$d = -367 \bmod 3120 = 3120 - 367 = 2753$$

Cặp khóa thu được: Public Key $(e = 17, n = 3233)$ và Private Key $(d = 2753, n = 3233)$.

> **Khuyến nghị tiêu chuẩn:**
> Mô hình trên là Textbook RSA. Tiêu chuẩn RFC 8017 ([3]) yêu cầu kích thước khóa tối thiểu 2048-bit và bắt buộc kết hợp cơ chế đệm an toàn (RSA-OAEP) để chống các kỹ thuật tấn công chọn bản mã.

6. Cài đặt RSA bằng Python

Nhóm đã tự triển khai toàn bộ các phép toán nền tảng của RSA trong tệp `src/rsa.py` bằng ngôn ngữ Python thuần, hoàn toàn không phụ thuộc vào thư viện mật mã học bên ngoài.

6.1. Bảng đặc tả các hàm chính

Tên hàm	Mô tả chức năng & Giải thuật
`extended_gcd(a, b)`	Cài đặt giải thuật Euclid mở rộng: đệ quy tìm ước chung lớn nhất và các hệ số Bézout x, y sao cho $ax + by = \gcd(a, b)$. Dùng để tính số mũ bí mật d.
`generate_rsa_keys(p, q)`	Giai đoạn sinh khóa: Tính $n = p \times q$, $\varphi = (p-1)(q-1)$, chọn $e = 17$, tính d qua `extended_gcd(e, phi)`, trả về cặp `((e, n), (d, n))`.
`rsa_encrypt(pub_key, M)`	Giai đoạn mã hóa: Áp dụng công thức $C = M^e \bmod n$ sử dụng hàm lũy thừa modulo tối ưu `pow(M, e, n)`.

`rsa_decrypt(priv_key, C)`	Giai đoạn giải mã: Áp dụng công thức $M = C^d \bmod n$ thông qua `pow(C, d, n)`.

6.2. Mã nguồn cài đặt giải thuật Euclid mở rộng và RSA

```
def extended_gcd(a, b):
    """Giải thuật Euclid mở rộng tìm gcd(a, b) và x, y thỏa mãn a*x + b*y = gcd"""
    if a == 0:
        return b, 0, 1
    gcd, x1, y1 = extended_gcd(b % a, a)
    x = y1 - (b // a) * x1
    y = x1
    return gcd, x, y

def generate_rsa_keys(p=61, q=53, e=17):
    """Sinh cặp khóa Public Key (e, n) và Private Key (d, n)"""
    n = p * q
    phi = (p - 1) * (q - 1)
    gcd, x, _ = extended_gcd(e, phi)
    d = (x % phi + phi) % phi  # Đảm bảo d > 0
    return (e, n), (d, n)

def rsa_encrypt(public_key, plaintext_num):
    e, n = public_key
    return pow(plaintext_num, e, n)

def rsa_decrypt(private_key, ciphertext_num):
    d, n = private_key
    return pow(ciphertext_num, d, n)
```

> **Điểm cần nhớ:**
> Cả hai hàm `rsa_encrypt` và `rsa_decrypt` đều thực thi thuật toán tính lũy thừa theo mô-đun (`pow(base, exp, mod)`), chỉ khác nhau ở số mũ: quá trình mã hóa sử dụng số mũ công khai e, trong khi quá trình giải mã sử dụng số mũ bí mật d.

7. Ví dụ RSA – Mã hóa và giải mã

Để kiểm chứng tính đúng đắn của giải thuật toán học đã lập trình, nhóm thực hiện chạy thử nghiệm quy trình với bộ tham số:

- Cặp khóa công khai / bí mật: $e = 17$, $d = 2753$, $n = 3233$.
- Thông điệp dạng số cần mã hóa: $M = 125$.

Giai đoạn	Công thức toán học	Kết quả
Thông điệp gốc	Giá trị ban đầu M	125

Mã hóa bằng Public Key	$C = M^e \bmod n = 125^{17} \bmod 3233$	1516
Giải mã bằng Private Key	$M_{\text{giải mã}} = C^d \bmod n = 1516^{2753} \bmod 3233$	125

7.1. Chuỗi chuyển đổi dữ liệu

$$M = 125 \xrightarrow{\text{Mã hóa với } e=17} C = 1516 \xrightarrow{\text{Giải mã với } d=2753} M_{\text{khôi phục}} = 125$$

Trong chương trình Python, điều kiện xác nhận:

```
if M == M_giai_ma:
    print("Dữ liệu được khôi phục chính xác 100%!")
```

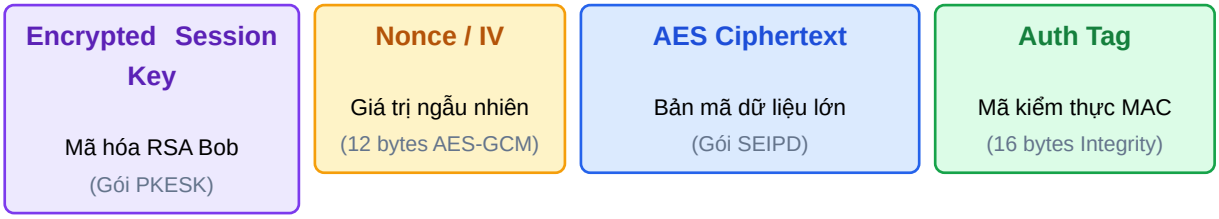
Kết quả thực nghiệm chứng minh thuật toán RSA tự cài đặt tái hiện chính xác nguyên lý toán học của hệ mật mã hóa khóa công khai.

8. Tích hợp RSA và AES trong Hybrid Encryption

Trong mô hình mã hóa lai hoàn chỉnh, RSA tuyệt đối không tham gia trực tiếp vào việc mã hóa khối dữ liệu thông điệp dài mà đóng vai trò là “két sắt” bảo vệ khóa đối xứng (Session Key). AES đảm nhận toàn bộ việc mã hóa dữ liệu tốc độ cao.

8.1. Cấu trúc gói tin dữ liệu đóng gói (Packet Payload)

Khi dữ liệu được truyền tải qua kênh mạng theo mô hình PGP (tương ứng với các gói PKESK và SEIPD trong RFC 4880), thông điệp đóng gói gồm 4 thành phần thiết yếu sau:



Hình 3: Cấu trúc gói tin dữ liệu hoàn chỉnh truyền qua mạng

8.2. Phân công nhiệm vụ hai phía

Phía Alice (Mã hóa)	Phía Bob (Giải mã)

• Sinh Session Key ngẫu nhiên (128-bit). • Dùng AES-GCM mã hóa thông điệp bằng Session Key to tạo ra Ciphertext, Nonce và Authentication Tag. • Dùng Public Key RSA của Bob mã hóa Session Key to Encrypted Key. • Ghép 4 thành phần thành gói tin duy nhất gửi đi.	• Tiếp nhận toàn bộ gói tin từ Alice qua mạng. • Dùng Private Key RSA của Bob giải mã Session Key. • Dùng Session Key và Nonce giải mã Ciphertext bằng AES-GCM. • Đối chiếu Authentication Tag để kiểm tra tính toàn vẹn và chống giả mạo trước khi nhận thông điệp gốc.

8.3. Mã nguồn tích hợp then chốt (`src/hybrid_demo.py`)

```
# Phía Alice: Mã hóa dữ liệu bằng AES-GCM và bảo vệ khóa phiên bằng RSA
session_key = os.urandom(16)
cipher_aes = AES.new(session_key, AES.MODE_GCM)
ciphertext, auth_tag = cipher_aes.encrypt_and_digest(plaintext)
enc_session_key = rsa_encrypt(bob_pub_key, int.from_bytes(session_key, 'big') %
bob_pub_key[1])

# Phía Bob: Dùng Private Key RSA khôi phục khóa phiên và xác thực Tag
recovered_key = rsa_decrypt(bob_priv_key, enc_session_key)
cipher_bob = AES.new(session_key, AES.MODE_GCM, nonce=package["nonce"])
plaintext_recovered = cipher_bob.decrypt_and_verify(ciphertext, auth_tag)
```

Lưu ý kỹ thuật và tính minh bạch:

- **Chế độ AES-GCM:** Sử dụng **Nonce** (Number used once) nhằm triệt tiêu hiện tượng trùng lặp khối mã và sử dụng **Authentication Tag** (128-bit) để bảo đảm toàn vẹn dữ liệu.
- **Ranh giới triển khai:** Nhóm tự lập trình thuật toán số học RSA để nắm vững nguyên lý toán học, đồng thời tích hợp thư viện AES chuẩn công nghiệp (`Cryptodome`) để bảo đảm hiệu năng và tính an toàn mật mã.

9. Demo chương trình và kết quả kiểm thử

Để đánh giá toàn diện tính đúng đắn, khả năng chống can thiệp và xử lý lỗi của chương trình Python (`src/hybrid_demo.py`), nhóm đã thiết lập 3 kịch bản kiểm thử trọng tâm:

Kiểm thử	Kịch bản thử nghiệm	Kết quả quan sát & Phân tích
Test 01	Bob sử dụng đúng Private Key tương ứng với Public Key của mình.	Khôi phục thành công 100% nội dung thông điệp gốc ban đầu. Khóa phiên và dữ liệu được giải mã chính xác.

Test 02	Kẻ tấn công (Man-in-the-Middle) can thiệp, đảo 1 bit trong Ciphertext trước khi Bob giải mã.	Phát hiện can thiệp: Thư viện bắt lỗi ngoại lệ `ValueError: MAC check failed`. Bản tin bị hủy bỏ ngay lập tức.
Test 03	Giải mã bằng một Private Key không khớp (khóa của bên thứ ba Eve).	Thất bại: Phép tính RSA cho ra giá trị Session Key sai lệch, dẫn tới giải mã AES thất bại và ném ngoại lệ.

9.1. Minh chứng thực nghiệm (Terminal Execution Log)

Dưới đây là nhật ký xuất trực tiếp từ terminal khi thực thi chương trình `python3 src/hybrid_demo.py`:

```
======================================================================
DEMO PGP HYBRID ENCRYPTION (RSA + AES-GCM)
======================================================================

[ALICE] Thông điệp gốc: "Báo cáo tiến độ Nhóm 7: PGP Hybrid Encryption hoạt động
chính xác!"
[ALICE] Mã hóa hoàn tất:
  + Encrypted Session Key (RSA) : 2843
  + Nonce (AES-GCM)              : 48241c998fc06ff8e676cbb77d3ba152
  + Ciphertext (AES)            : e33b37b786e44a47b86fd935c285367ae60ccea3... (81
bytes)
  + Authentication Tag          : f36635e20b731180628dcfd7aaceab49

----------------------------------------------------------------------
TEST CASE 01: Bob dùng đúng Private Key của mình
[BOB] Giải mã thành công: "Báo cáo tiến độ Nhóm 7: PGP Hybrid Encryption hoạt động
chính xác!"
>>> KẾT QUẢ: [PASSED] Khôi phục chính xác 100% dữ liệu.

----------------------------------------------------------------------
TEST CASE 02: Kẻ tấn công sửa đổi 1 byte trong Ciphertext
[BOB] CẢNH BÁO AN TOÀN: Phát hiện dữ liệu bị can thiệp!
      Chi tiết ngoại lệ: MAC check failed (Authentication Tag không khớp)
>>> KẾT QUẢ: [PASSED] Chặn thành công tấn công sửa đổi bản mã.

----------------------------------------------------------------------
TEST CASE 03: Giải mã bằng Private Key không hợp lệ (Khóa của Eve)
[EVE] Thất bại: Không giải mã được Session Key và bản mã.
      Chi tiết ngoại lệ: MAC check failed (Sai Session Key dẫn đến xác thực thất bại)
>>> KẾT QUẢ: [PASSED] Từ chối truy cập trái phép khi sai khóa.
======================================================================
```

Nhận xét kết quả kiểm thử:
Ba tình huống kiểm thử trên chứng minh rằng mô hình kết hợp RSA và AES-GCM không chỉ bảo vệ tính bí mật tuyệt đối của nội dung thông điệp trên đường truyền mà còn chủ động phát hiện mọi nỗ lực giả mạo, can thiệp hoặc thay đổi dữ liệu trái phép.

10. Kết quả đạt được và hướng phát triển

Dưới đây là tổng hợp tiến độ nghiên cứu của nhóm cùng lộ trình hoàn thiện cho đồ án trong giai đoạn tiếp theo:

10.1. Tổng kết khối lượng công việc

Đã thực hiện	Hướng phát triển tiếp theo
• Nắm vững cơ sở lý thuyết về mô hình Hybrid Encryption và cấu trúc chuẩn PGP/OpenPGP. • Tự lập trình giải thuật RSA toán học bằng Python (Euclid mở rộng, tính modulo). • Minh họa thành công chu trình mã hóa và giải mã số học RSA. • Xây dựng chương trình Hybrid tích hợp RSA – AES và hoàn thành bộ 3 kiểm thử cơ bản.	• Rà soát, làm sạch và tối ưu hóa mã nguồn toàn bộ hệ thống tích hợp. • Mở rộng chức năng tạo chữ ký số (Digital Signature) bằng RSA và hàm băm SHA-256 để đảm bảo tính chống chối bỏ. • Kiểm thử hệ thống với dữ liệu thực tế lớn (tệp tin văn bản, ảnh, nhị phân). • Đo đạc thời gian thực thi (độ trễ và thông lượng) giữa mã hóa thuần RSA so với Hybrid Encryption.

10.2. Lộ trình kế hoạch triển khai giai đoạn tới (Roadmap)

Thời gian	Nhiệm vụ trọng tâm	Kết quả dự kiến đầu ra
Tuần 1	Hoàn thiện module Chữ ký số	Tích hợp RSA + SHA-256 để ký và xác thực chữ ký điện tử.
Tuần 2	Thực nghiệm tệp tin dung lượng lớn	Xử lý mã hóa/giải mã các file nhị phân, hình ảnh, tài liệu PDF.
Tuần 3	Đo đạc Benchmark & Hiệu năng	Biểu đồ so sánh thời gian thực thi giữa RSA thuần và Hybrid Encryption.
Tuần 4	Hoàn thiện báo cáo & Slide bảo vệ	Đóng gói mã nguồn hoàn chỉnh và tài liệu báo cáo nghiệm thu.

Định vị phạm vi đề tài:
Phạm vi hiện tại: Chương trình là bản mô phỏng trực quan cơ chế mã hóa lai RSA – AES phục vụ mục tiêu học tập và nghiên cứu cấu trúc PGP. Nhóm chưa đồng nhất bản demo này với một phần mềm OpenPGP hoàn chỉnh (như GnuPG), vốn đòi hỏi định dạng gói dữ liệu RFC 4880, hệ thống chứng thực Web of Trust và cơ chế quản lý khóa an toàn trên đĩa cứng.

11. Câu hỏi thảo luận và phản biện (Q&A)

Để chuẩn bị tốt nhất cho buổi bảo vệ tiến độ trước giảng viên hướng dẫn, toàn thể thành viên trong nhóm đã tổng hợp và chuẩn bị kỹ các câu hỏi phản biện cốt lõi:

Hỏi: RSA và AES khác nhau cơ bản ở điểm nào?

- **AES:** Hệ mật mã đối xứng, người gửi và người nhận dùng chung một khóa bí mật, thuật toán chủ yếu dựa trên các phép thay thế và hoán vị trên ma trận byte (mạng SPN), tốc độ xử lý phần cứng cực kỳ nhanh.
- **RSA:** Hệ mật mã bất đối xứng, gồm cặp Public Key và Private Key, hoạt động dựa trên lý thuyết số học modulo và độ khó phân tích số nguyên lớn, chi phí tính toán lớn hơn hàng ngàn lần so với AES.

Hỏi: Khóa công khai dùng để mã hóa khóa phiên thuộc về ai?

Khóa công khai đó thuộc về **người nhận (Bob)**. Bất kỳ ai muốn gửi tin nhắn an toàn cho Bob đều dùng Public Key của Bob để mã hóa khóa phiên. Chỉ duy nhất Bob với Private Key tương ứng mới có thể giải mã lấy lại khóa phiên.

Hỏi: Khóa phiên (Session Key) là gì và được tạo ra ở đâu?

Khóa phiên là một khóa đối xứng ngẫu nhiên (độ dài 128 hoặc 256 bit), được sinh ra ngẫu nhiên tại **phía người gửi (Alice)** ngay trước khi thực hiện mã hóa thông điệp, chỉ có giá trị sử dụng một lần duy nhất cho phiên truyền thông đó.

Hỏi: Cơ chế nào phát hiện bản mã bị kẻ tấn công sửa đổi trên đường truyền?

Khi sử dụng chế độ mã hóa xác thực **AES-GCM**, thuật toán tự động sinh ra giá trị **Authentication Tag** (MAC). Nếu bất kỳ bit nào của bản mã bị thay đổi trên đường truyền, giá trị tag tính toán lại ở phía nhận sẽ không khớp, Bob sẽ lập tức phát hiện và hủy bỏ gói tin.

Hỏi: Vì sao mã RSA tự viết với p = 61, q = 53 không thể ứng dụng trong bảo mật thực tế?

Vì $n = 3233$ quá nhỏ, bất kỳ máy tính nào cũng có thể phân tích thành 61×53 trong thời gian tính bằng microsecond, từ đó kẻ tấn công dễ dàng tính ra $\varphi(n) = 3120$ và tìm được khóa bí mật d. Trong thực tế, p, q phải có độ dài tối thiểu 1024-bit hoặc 2048-bit trở lên.

Hỏi: Cần bổ sung những gì để đề tài trở thành một hệ thống PGP/OpenPGP hoàn chỉnh?

- Bổ sung cơ chế đệm an toàn **OAEP** cho RSA để chống tấn công chọn bản mã;
- Thêm chức năng nén dữ liệu (ZIP hoặc ZLIB) trước khi mã hóa để giảm kích thước và triệt tiêu tính dư thừa thống kê;
- Thêm chữ ký số (**Digital Signature**) bằng RSA + SHA-256 để xác thực danh tính người gửi và chống chối bỏ;
- Quản lý khóa và định dạng gói tin theo chuẩn **RFC 4880** / **RFC 9580**.

TÀI LIỆU THAM KHẢO

[1] W. Stallings, *Cryptography and Network Security: Principles and Practice*, 7th a.b. Pearson, 2017.

[2] M. Dworkin, “Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC”, NIST Special Publication 800–38D, 2007.

[3] K. Moriarty, B. Kaliski, J. Jonsson, và A. Rusch, “PKCS #1: RSA Cryptography Specifications Version 2.2”, RFC 8017, 2016.

[4] J. Callas, L. Donnerhacke, H. Finney, D. Shaw, và R. Thayer, “OpenPGP Message Format”, RFC 4880, 2007.

[5] P. Wouters và D. Huigens, “OpenPGP”, RFC 9580, 2024.

[6] National Institute of Standards and Technology, “Advanced Encryption Standard (AES)”, Federal Information Processing Standards Publication 197, 2001.

[7] R. L. Rivest, A. Shamir, và L. Adleman, “A Method for Obtaining Digital Signatures and Public-Key Cryptosystems”, *Communications of the ACM*, tập 21, số 2, tr 120–126, 1978.